

25.05.2022

25 May 2022 - Activity of the ANSPDCP

On May 25, 2022, four years will have passed since the application of the General Data Protection Regulation (EU Regulation No. 679/2016 of the European Parliament and of the Council on the protection of natural persons with regard to the processing of personal data and on the free movement of such data, and repealing Directive 95/46/EC - GDPR), which marked a turning point in ensuring uniform rules within the community space.

On this occasion, we emphasize that during the four years of the application of the GDPR, operators in the public and private sectors have continued to implement the rules for processing personal data, especially those regarding the information of natural persons, the effective respect of the rights of natural persons (the right of access, the right to rectification, the right to erasure - "the right to be forgotten," the right to restriction of processing, the right to data portability, the right to object, the right not to be subject to a decision based solely on automated processing, the right to lodge a complaint with a supervisory authority), and the assurance of confidentiality and security in the processing of personal data.

The National Supervisory Authority continued its monitoring and control activities regarding the legality of personal data processing. The significant number of complaints, notifications, and requests for opinions received over the four years demonstrates an increase in the level of public awareness regarding the rights they benefit from, as well as the interest of operators in complying with European rules.

In the context of celebrating four years since the application of the GDPR, we present a summary of the most significant aspects of the activity of the National Supervisory Authority carried out during the first four months of 2022.

Thus, in the first four months of 2022, the National Supervisory Authority received 1,345 complaints, notifications, and reports regarding security incidents, based on which 129 investigations were opened.

As a result of the investigations carried out during this period, 17 fines were imposed, totaling 169,158 lei (equivalent to 35,100 euros). Additionally, during the control activity, 34 warnings were issued, and 23 corrective measures were ordered.

Regarding the complaint resolution activity, the National Supervisory Authority received 1,235 complaints in the first four months of the current year, based on which 80 investigations were initiated. During the same period, data operators submitted 48 notifications regarding data security breaches and 62 reports concerning possible non-compliance with the provisions of the GDPR. As a result of these, 49 investigations were initiated ex officio.

The complaints, notifications, and reports regarding security incidents received by the National Supervisory Authority during this period mainly concerned the following aspects:

- processing of images through video surveillance systems,
- violation of the rights of data subjects,
- violation of the principles set forth by the GDPR,
- receipt of unsolicited commercial messages,
- disclosure of data without the consent of the data subjects,
- violation of security and confidentiality measures,
- processing of data without legal basis.

At the same time, in the first four months of 2022, our institution received a total of 338 requests for issuing opinions regarding various aspects related to the interpretation and application of the GDPR and other relevant regulations.

The National Supervisory Authority issued opinions on 40 draft normative acts submitted by institutions and public authorities, which involved analyzing complex aspects regarding the processing of personal data.

During the same period, requests for approval of Binding Corporate Rules (BCRs) submitted by 8 multinational companies were analyzed. Additionally, the National Supervisory Authority acted as a

co-reviewer for the BCR approval requests submitted by 2 companies during this period.

The National Supervisory Authority carried out a series of information actions aimed at promoting the rules for the protection of personal data in the first four months of 2022.

Thus, several events were organized to celebrate European Data Protection Day, including a Conference, and the "Guide on Data Processing by Homeowners' Associations" was launched, which includes clarifications regarding the proper application of data protection regulations by homeowners' associations, posted on the website of the National Supervisory Authority www.dataprotection.ro. A brochure containing relevant elements from the activity of the National Supervisory Authority in 2021 was also posted, in both Romanian and English.

At the same time, in 2022, the National Supervisory Authority...

of the absence of any obligation to notify the Authority, since the evidence presented does not support such a claim. The court correctly noted that the operator had a legal obligation to notify the Authority of the security incident without delay, and the failure to do so constitutes a breach of the legal obligations established by the GDPR."

In conclusion, the legal framework and the decisions made by the courts affirm the importance of compliance with data protection regulations and the responsibilities of operators in ensuring the security and confidentiality of personal data. The Authority will continue to monitor and enforce compliance to protect the rights of individuals in relation to their personal data.

that notification would not be necessary.

The Court will find that from the Annexes presented by the appellant [Vreau Credit SRL] in the case file (...) there is no unequivocal consent from its clients for the transmission of personal data/processing of such data by a third party, let alone their use for inquiries in the credit bureau database conducted by a third party in relation to the contractual report.

It has been correctly noted from the study of the documents submitted by the appellant that its clients were not properly informed regarding the processing operations and that they were not asked for explicit, unequivocal consent, as they did not have the possibility to act in any way to express their free, specific, and informed will, as provided in art. 7 para. (1) in conjunction with art. 4 point 11 of the GDPR.

◆ Regarding the sanction of a total fine of 14,000 euros, by Decision no. 25 of 25.11.2022, final, the Bucharest Court of Appeal confirmed the measure ordered by the National Supervisory Authority against the operator Hora Credit IFN SA, rejecting its request to replace the three imposed fines with a warning sanction.

Thus, the appellate court noted that: "As correctly observed by the appellant ANSPDCP, the criteria for individualizing the sanction are those provided in art. 83 para. (2) of the GDPR," as well as the fact that "The provisions of art. 83 para. (4) must also be taken into account, according to which: 'in the event that an operator or a person authorized by the operator intentionally or negligently violates multiple provisions of this regulation for the same processing operation or for related processing operations, the total amount of the administrative fine may not exceed the amount provided for the most serious violation.' (...)

Therefore, in the case of violations of multiple provisions of the Regulation, as is the case here, in order to apply the sanction of 'warning,' it is necessary for the degree of social danger to be extremely low in relation to each of the identified breaches, which cannot be assessed 'as a whole,' depending on the conduct adopted by the person checked after the communication of the minutes.

(...) Analyzing each of the identified breaches, the Court will note that the first of these was sanctioned with a fine of 3,000 Euros," and "will observe that the sanctioned act, consisting of the communication of personal data to third parties without proving the application of effective verification and validation mechanisms for the accuracy of the data, as well as for ensuring their confidentiality, represents an act of high social danger, involving the violation of some of the general principles of the Regulation, regulated by the provisions of art. 5 para. (1) letters d) and f) and art. 5 para. (2) of the GDPR.

Moreover, as previously stated, the appellant claimant [Hora Credit IFN SA] had a reasonable period of time from the entry into force of the Regulation until the commission of the acts, to adapt its conduct according to European norms, in order to ensure the protection guaranteed by the Regulation, but it

did not proceed in this manner, the verification mechanisms implemented by it - verification by telephone call of the data - being devoid of any efficiency from the perspective of confirming the reality of these data and ensuring the identity between the credit applicant and the holder of the communicated personal data.

The Court will observe that the fine imposed on the appellant claimant, of 3,000 Euros, is far from the maximum limit of the fine provided by the regulation, so that in relation to the seriousness of the identified act, it was necessary for it to be maintained by the court of first instance.

Additionally, (...) it will be observed that the criterion of art. 83 para. (2) letter a) is applicable, the appellant-claimant [Hora Credit IFN SA] being a professional specialized in granting loans to consumers, with obligations regarding the guarantee of the security of their personal data, which has illegally processed this data not just once, but repeatedly, even after being warned about the illegality of the processing.

Also, in relation to art. 83 para. (2) letter c) of the regulation, it is noted that the appellant-claimant, although warned about stopping the processing since July 2019, only took measures to protect the consumer in September of the same year, during which time the rights of the individual were repeatedly violated (...).

At the same time, the Court will take into account in evaluating the sanction the provisions of art. 83 para. (2) letter d), regarding "the degree of responsibility of the operator or the person authorized by the operator, taking into account the technical and organizational measures implemented by them under articles 25 and 32," noting that this [operator Hora Credit IFN SA] did not implement technical and organizational measures under the mentioned texts, capable of guaranteeing the security of personal data.

Considering these criteria for individualizing the sanction, the Court will observe that the fine of 3,000 Euros imposed by the authority for the commission of the first breach is fully justified, and there is no need to replace it with a 'warning.'

Regarding the second breach, the Court noted that "for the commission of this, a fine of 10,000 Euros was imposed, in relation to the provisions of art. 83 para. (4) letter a) of the Regulation, according to which: 'For violations of the following provisions, in accordance with paragraph (2), fines are applied... administrative of up to 10,000,000 EUR or, in the case of an enterprise, up to 2% of the total worldwide annual turnover corresponding to the previous financial year, taking into account the highest value.'"

The Authority considered the violation of Articles 25 and 32 of the Regulation, as previously stated, noting that the appellant-claimant did not comply with these legal provisions, despite being aware of them and failing to ensure an appropriate level of security capable of preventing the unlawful processing of data, by implementing the appropriate technical and organizational measures referred to in the indicated texts of the European act.

The Court will also observe that not only did the claimant fail to comply with these legal obligations, but when notified by the named (...) it did not adopt any corrective measures, but continued the unlawful processing of personal data, thus the criteria for individualizing the sanction from Article 83 letters a), c), and d) apply, leading to the conclusion that a fine was warranted, rather than a warning sanction, the act having a high degree of social danger, and the amount of the fine imposed is fully justified, given that it is much lower than the maximum level provided by law."

Regarding the third sanction, applied for the violation of the obligation to notify the National Supervisory Authority of the security incident, "the Court will observe that, also being a willful non-compliance with a legal obligation, followed by the continuation of the unlawful processing of personal data, the amount of the fine imposed of 1,000 Euros is justified. The non-compliance with a legal notification obligation, which led to the continuation of the unlawful behavior of the appellant-claimant, justifies the amount of the fine imposed, of only 1,000 Euros, the sanctioned act having a high degree of social danger, by affecting the rights of private individuals (...), considering also the provisions of Article 83 letter h) of Regulation 2016/679.

As correctly noted by the appellant-defendant, social danger is an essential characteristic, common to all acts that infringe the rule of law. At the same time, it indicates the extent to which the contravention

affects one of the values or social relationships protected by a normative act (in this case, the right to a private life protected both by Article 26 of the Constitution of Romania and by Regulation (EU) 2016/679).

Considering that the appellant-claimant did not adopt sufficient measures for the security of personal data, according to Articles 25 and 32 of the GDPR, in order to prevent the unauthorized and accessible disclosure of the personal data of its client (...), persisted in non-compliant behavior even after being informed of the violation and did not fulfill its legal obligation to notify the authority about the security risk, the Court will appreciate that the facts attributed to it present a high degree of social danger, thus the final fine imposed must be maintained."

♦ By Decision No. 1148/17.11.2020, final by lack of appeal, the Prahova Tribunal confirmed the fine imposed by the National Supervisory Authority on SC PROLEASING MOTORS SRL, in the amount of 15,000 Euros. Thus, regarding the act committed, the court found that: "the arguments regarding the non-existence of a violation cannot be upheld, since this [claimant SC PROLEASING MOTORS SRL] acknowledged that a security incident occurred which it notified to the Authority, its systems were vulnerable and accessible, it reported this to Cert-RO, sought the assistance of an IT consultant, and subsequently took a series of technical and organizational measures following the incident, all these aspects contradicting the non-existence of a violation.

In the same sense, the court opines that the claimant's obligation was all the more necessary as it showed that it is part of the network of an international corporation and implemented 'all Corporate Rules' of the group (...) of which it is an authorized dealer. Therefore, in light of the above, the court opines that the minutes are well-founded and legally drawn up, with no doubt leading to its annulment."

At the same time, regarding the request made by the claimant SC PROLEASING MOTORS SRL for the replacement of the fine with a warning, the court established that: "given the seriousness of the act, the principle of proportionality of the sanction was respected in its application, especially since the evidence presented clearly showed that the claimant did not take all due diligence to adopt and comply with the appropriate technical and organizational measures to ensure an appropriate level of security corresponding to the risks (...).

Moreover, when it comes to the nature or severity of the act, the legislator intended to individualize it through the amount of the fine, and regarding this amount, other considerations apart from the claimant's lack of diligence are already redundant."

♦ By Decision No. 3161/2020 06.11.2020, remaining final by lack of appeal, the Bucharest Municipality Tribunal confirmed the sanction of the fine in the amount of 2,500 Euros, imposed on the operator Royal President SRL by the National Supervisory Authority. Thus, regarding the commission of the act consisting of non-compliance with the provisions of Articles 15 and 12 paragraphs (3) and (4) of EU Regulation 679/2016, the court noted the following:

"Contrary to the claims of the plaintiff [Royal President SRL], the court finds that it has not provided evidence of communication within the time frame stipulated by law (...) of the response (...). Thus, although in the content of the summons, as well as in the letters sent to the defendant, the plaintiff claims to have made the communication within one month from the receipt of the request, no document has been submitted in this regard, and from the content of the acknowledgment of receipt attached in copy to the file (...) the date on which the communication took place is not evident."

Furthermore, regarding the act of non-compliance with Article 5 paragraph (1) letter f) in relation to Article 32 paragraph (1) letter b) of EU Regulation 679/2016, the court correctly noted that the contested minutes indicated that the plaintiff had not implemented adequate technical and organizational measures to ensure the confidentiality of the personal data of the data subject, as well as to ensure an appropriate level of security corresponding to the risk of processing for the rights and freedoms of the data subject.

As such, the court concluded that: "the consequence of not taking these measures resulted in the compromise of the confidentiality of personal data (...), generating unauthorized disclosure of personal

data (...) (name, surname, identity card series and number, personal identification number, information related to accommodation at Hotel Royal President) to an incorrect recipient."

In this context, the court noted the following: "Although the plaintiff [Royal President SRL] claims that the person who requested the communication of the invoice containing personal data (...), was identified by phone in compliance with the provisions of GDPR, the court finds that the mentioned invoice was sent to an email address not found in the accommodation record. Thus, upon reviewing the content of the accommodation record, the court finds that the fields for the phone number and email address were left unfilled, and the address to which the invoice was sent (...) had not been previously used in correspondence between the parties nor obtained directly from [the data subject]."

In light of the above findings and considering the provisions of Article 12 paragraph (6) of GDPR, according to which, if there are reasonable doubts regarding the identity of the individual submitting the request mentioned in Articles 15-21, the operator may request the provision of additional information necessary to confirm the identity of the data subject, the court considers that a mere telephone confirmation of the accuracy of an email address is not sufficient, and the operator has the obligation to take all reasonable measures to verify the identity of a data subject requesting access to data, especially in the context of online services and online identifications.

Consequently, the court holds that the plaintiff has not proven a factual situation distinct from that established by the contravention minutes, namely, it has not demonstrated that it adopted sufficient personal data security measures, according to Articles 25 and 32 of GDPR, to prevent unauthorized disclosure of personal data of [the data subject].

Additionally, regarding the document titled Procedure on the Protection of Personal Data accompanied by a table of individuals who have acknowledged and signed it, it is noted that the content does not indicate the date on which it was prepared nor the date on which it was communicated to the plaintiff's employees. Moreover, even if the document had been prepared prior to the incident on August 28, 2019, the court considers that the actions taken by the plaintiff were neither sufficient nor effective in ensuring an appropriate level of security, resulting in the infringement of [the data subject]'s right to personal data protection."

◆ By Decision No. 3 of January 27, 2022, the Bucharest Court of Appeal definitively confirmed the fine of 3,000 euros imposed by the National Supervisory Authority in 2020 on the operator Dante International, noting that: "In this case, the sanction imposed by the authority fully corresponds to these proportionality requirements, given that, as already noted, the act was committed under conditions where the person who filed the complaint expressly requested that the appellant-plaintiff [Dante International] no longer send them commercial messages.

At the same time, from the content of the summons and the appeal request, it does not appear that the appellant-plaintiff [Dante International] understood that it had carried out an unlawful processing, its arguments being centered on the fact that it acted fully in accordance with legal provisions, by attempting to disguise a direct marketing message as a transactional message.

Furthermore, the Court finds that the appellant-plaintiff has previously been sanctioned for violations of legal provisions regarding the processing of personal data (...).

On the other hand, the amount of the fine established by the appellant-defendant through the contravention minutes (equivalent to 3,000 euros) is oriented towards the minimum specially established by law and is significantly lower than sanctions imposed on other economic operators for similar acts."

◆ By Civil Decision No. 9 of April 13, 2022, final, the Cluj Court of Appeal confirmed the fine of 100,000 euros imposed by the National Supervisory Authority on Banca Transilvania for violating Article 32 paragraphs (1) and (2) in conjunction with Article 5 paragraph (1) letter f) of the General Data Protection Regulation.

Also, the same favorable solution for the National Supervisory Authority was pronounced at first instance, through Civil Judgment no. 1309 of May 6, 2021, of the Cluj Tribunal, upheld in full by the

appellate court.

To decide thus, "the Tribunal emphasizes that the Regulation introduced a much higher level of accountability for the data controller compared to Directive 95/46/EC on data protection, and Articles 24 and 32 of the Regulation stipulate that controllers 'take into account the state of the art, the costs of implementation, and the nature, scope, context, and purposes of processing, as well as the risks with varying degrees of probability and severity for the rights and freedoms of natural persons that processing presents.'"

Furthermore, the court correctly noted the following aspects:

"In this case, to prove its diligent conduct regarding the training of personnel in the field of personal data protection, the claimant submitted a series of internal regulations as well as evidence of organizing courses on this topic; however, it is important to emphasize that the actual participation of the staff in these courses was not proven, nor was there any effective application of a method to verify the acquisition of this knowledge and information.

Moreover, the aspects invoked by the claimant regarding the measures taken to implement the provisions of the Regulation are contradicted by the facts established by the unchallenged contravention report, which attest to the intentional, unauthorized disclosure by individuals under the authority of the Bank of a significant [set] of personal data (some of which are classified as extremely sensitive) to a very large number of persons.

The nonchalance with which the claimant's employees acted, transmitting the personal data of the bank's client from one to another and subsequently to third parties via the WhatsApp application, attests not only to a lack of knowledge of the working procedures regarding the processing of personal data but, more importantly (and more seriously), to their inability to identify and qualify the data they accessed as personal data, which indicates a severe lack of effective training.

Therefore, although the claimant submitted copies of various internal procedures to the file, it did not prove, on the one hand, the effective training of the three employees who caused the security incident, and on the other hand, that it applied the control and evaluation mechanisms developed to ensure that its employees had acquired the mentioned internal regulations.

Thus, the documents presented by the claimant, in proof of the implementation of appropriate technical and organizational measures, do not serve to demonstrate the assurance of an adequate level of security regarding the ability to ensure confidentiality and the periodic testing, evaluation, and assessment of the effectiveness of the technical and organizational measures to guarantee the security of processing."

Regarding the consequences of the breach, the Cluj Tribunal noted that "these were correctly qualified by the defendant as serious in relation to the quantity of personal data disseminated by the Bank's employees, their sensitive nature, the manner of dissemination (via the internet, with the email containing the Bank's client data circulating intensively in the public space, with synthetic information being taken even by blogs, TV channels, and news websites), the extremely large number of persons who gained access to the Bank's client data for an indeterminate period of time, as a result of the transmission of information through various means, all these aspects being capable of providing a correct picture regarding the scope and severity of the consequences of the security incident.

The claimant also acknowledged, regarding the manner of transmitting personal data, that the measures taken to limit the consequences of the security breach were not "feasible," the extent of their dissemination in the public space being clearly out of control."

In conclusion, the first-instance court correctly concluded that:

"For all the factual and legal considerations mentioned above, the tribunal will conclude that the fine in the amount of 100,000 euros is legal, 'effective, proportional, and dissuasive' and was established taking into account the nature, gravity, and consequences of the breach, as well as all other criteria provided by the Regulation, criteria that were analyzed by the defendant in a coherent and objective manner."